

# Threat Hunting Report

**Name:** [Solomon Mwaura]

**Date:** February 19, 2026

## Introduction

**Purpose:** Provide an overview of the lab, the scenario being analyzed, and the objectives of the exercise.

**Scenario Summary:** APT29 (Cozy Bear) launched a targeted cyber-espionage campaign against DataSecure Inc. to exfiltrate sensitive financial data. The attackers gained initial access via a spearphishing link, utilized fileless malware and zero-day exploits to establish a foothold, and leveraged native Windows tools (RDP, WMI, PowerShell) to move laterally and evade detection before exfiltrating encrypted data over HTTPS.

**Lab Objective:** This lab focuses on analyzing an attack scenario and mapping the observed behaviors to MITRE ATT&CK techniques to better understand adversary tactics and develop mitigation strategies.

## Hypothesis

**Purpose:** Define a clear hypothesis based on the provided attack scenario.

**Hypothesis:** Based on the scenario details, it is hypothesized that APT29's primary goal was the stealthy exfiltration of sensitive financial data (Espionage). To achieve this, the adversary likely relied heavily on "Living off the Land" (LotL) techniques—such as PowerShell, RDP, and WMI—combined with custom malware and zero-day/known exploits to minimize their footprint, bypass endpoint defenses, and maintain persistent, highly privileged access.

## Observed Activities and TTPs

**Purpose:** Document the key activities observed in the scenario and map them to MITRE ATT&CK techniques.

| Observed Activity                                   | MITRE ATT&CK Technique       | Technique ID |
|-----------------------------------------------------|------------------------------|--------------|
| Email containing a malicious link sent to executive | Phishing: Spearphishing Link | T1566.002    |

|                                                                               |                                                                   |                   |
|-------------------------------------------------------------------------------|-------------------------------------------------------------------|-------------------|
| Dropper deploying fileless payload directly in memory via PowerShell          | Command and Scripting Interpreter: PowerShell                     | T1059.001         |
| Malicious DLL loaded through a legitimate service for persistence             | Hijack Execution Flow: DLL Side-Loading / Search Order Hijacking  | T1574.002         |
| Exploited a known vulnerability in the Windows Kernel for system-level access | Exploitation for Privilege Escalation                             | T1068             |
| Infiltrated additional systems using RDP and WMI                              | Remote Services: Remote Desktop Protocol / WMI                    | T1021.001 / T1047 |
| Encrypted financial data transferred via custom tool over HTTPS               | Exfiltration Over Alternative Protocol: Encrypted Non-C2 Protocol | T1048             |
| Modified system logs and used a script to erase malware traces                | Indicator Removal: Clear Windows Event Logs                       | T1070.001         |

## Anomalies and Patterns

**Purpose:** Highlight suspicious or unusual behaviors in the scenario.

Several key anomalies deviate from standard network and endpoint operations. First, the execution of PowerShell commands directly from memory, specifically spawned by a web browser or email client process following a link click, is a highly anomalous behavior. Legitimate administrative PowerShell use typically originates from authenticated administrative accounts, not standard user processes.

Second, the pattern of lateral movement is highly suspicious. The sudden use of Remote Desktop Protocol (RDP) and Windows Management Instrumentation (WMI) originating from a single executive's workstation to probe or connect to multiple other internal systems is a classic indicator of internal reconnaissance and lateral movement. Standard user accounts rarely initiate WMI calls across a network.

Finally, the modification and deletion of system logs, combined with an abnormal outbound HTTPS data transfer of encrypted files (which would likely show up as a large, sustained bandwidth spike or a connection to an uncategorized external IP), represent severe deviations from normal system baseline behaviors.

## Investigation and Validation

**Purpose:** Validate the findings by confirming their alignment with the MITRE ATT&CK framework and known adversary behaviors.

The observed activities strongly align with the documented operational patterns of APT29 (Cozy Bear). Threat intelligence confirms that APT29 frequently employs highly targeted spearphishing campaigns (T1566) to establish initial access. Furthermore, their use of custom, stealthy droppers and fileless malware executing in memory (T1059.001) perfectly matches their objective of defense evasion and leaving a minimal forensic footprint on the disk.

The lateral movement and persistence mechanisms also validate the hypothesis. APT29 is known for "Living off the Land," utilizing native OS utilities like WMI (T1047) and RDP (T1021.001) rather than dropping custom lateral movement tools, which would be more easily caught by antivirus software. Their exploitation of a Windows Kernel vulnerability (T1068) to achieve SYSTEM privileges allows them the necessary access to hijack legitimate services for DLL loading (T1574) and to clear event logs (T1070.001).

By cross-referencing these steps with the MITRE ATT&CK framework, we confirm that the sequence of events—from initial access via spearphishing to stealthy HTTPS exfiltration—is a textbook representation of a sophisticated, state-sponsored cyber-espionage campaign.

## Mitigation Strategies

**Purpose:** Suggest ways to prevent or mitigate the identified techniques.

| Technique                                                 | Mitigation Strategy                                                                                                                                                                          |
|-----------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Phishing: Spearphishing Link (T1566.002)                  | Implement advanced anti-phishing/URL filtering solutions. Conduct routine phishing awareness training. Use multi-factor authentication (MFA) to limit the impact of compromised credentials. |
| Command and Scripting Interpreter: PowerShell (T1059.001) | Enable PowerShell Script Block Logging to monitor execution. Enforce strict execution policies and use Just                                                                                  |

|                                                                |                                                                                                                                                                                                                       |
|----------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                                                | Enough Administration (JEA) to limit PowerShell capabilities for standard users.                                                                                                                                      |
| <b>Exploitation for Privilege Escalation (T1068)</b>           | Implement a robust, prioritized patch management system to rapidly deploy updates for critical OS vulnerabilities (like kernel exploits). Use Endpoint Detection and Response (EDR) to detect exploitation behaviors. |
| <b>Remote Services: RDP / WMI (T1021.001 / T1047)</b>          | Disable RDP and WMI if they are not required. If required, restrict access via network segmentation, enforce MFA, and limit usage to specific, monitored jump servers and administrative accounts.                    |
| <b>Hijack Execution Flow: DLL Side-Loading (T1574.002)</b>     | Audit and restrict file and directory permissions to prevent standard users from writing to locations where legitimate services search for DLLs. Ensure software is compiled with safe DLL search modes enabled.      |
| <b>Indicator Removal: Clear Windows Event Logs (T1070.001)</b> | Forward all crucial system and security event logs to an external, centralized SIEM immediately upon generation. Ensure the SIEM utilizes an append-only architecture so attackers cannot modify stored logs.         |